

Security+ 3.1 · Infrastructure Considerations

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 3.1 — Infrastructure

Considerations (13:48) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Considerações de design: RESILIENCY (sobreviver a falha — cluster, load balancing, RAID, multi-AZ/Região); CUSTO (CAPEX compra servidor vs OPEX pay-per-use); RESPONSIVENESS (latência — CDN perto do usuário); SCALABILITY (scale out = +máquinas é melhor).

Highlights que a prova cobra

- 99.9% de uptime = ~8h45 por ano permitindo downtime; 99.99% = 52 min
- Elasticidade: escala pra cima E pra baixo conforme demanda
- Redundância N+1 = sobrevive 1 falha; 2N = sobrevive 2

Dicas de prova & Cenários Típicos

- 'ability to add/remove resources based on demand' = elasticidade
- 'uptime of 99.99%' = alta disponibilidade

Cenário clássico de exame: Cenário: 'serviço precisa tolerar falha de um datacenter inteiro' = multi-AZ / multi-region.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.1 — Infrastructure Considerations)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. O que é escalabilidade vertical (scale up)?

- A)** Adicionar mais instâncias
- B)** Aumentar recursos (CPU/RAM) da instância existente
- C)** Distribuir carga entre regiões
- D)** Implementar auto scaling

2. Aumentar capacidade adicionando MAIS máquinas (não máquinas maiores) é escalar:

- A)** Horizontalmente (scale out)
- B)** Verticalmente (scale up)
- C)** Pra baixo
- D)** Manualmente

3. Vários clientes dividindo a mesma infra física do provedor, isolados por software, é:

- A)** Multi-tenancy
- B)** Air gap
- C)** Colocation
- D)** On-premises

4. Ajustar automaticamente o número de instâncias conforme a demanda sobe/desce:

- A)** Auto scaling
- B)** Load balancing
- C)** Snapshot
- D)** Failover

5. Cenário corporativo (Infrastructure Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: '99.9% de uptime = ~8h45 por ano permitindo downtime; 99.99% = 52 min'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 99.9% de uptime = ~8h45 por ano permitindo downtime; 99.99% = 52 min...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Infrastructure Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'Elasticidade: escala pra cima E pra baixo conforme demanda'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Elasticidade: escala pra cima E pra baixo conforme demanda...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Infrastructure Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'Redundância N+1 = sobrevive 1 falha; 2N = sobrevive 2'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Redundância N+1 = sobrevive 1 falha; 2N = sobrevive 2...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Infrastructure Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'ability to add/remove resources based on demand' = elasticidade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'ability to add/remove resources based on demand' = elasticidade...

9. Cenário corporativo (Infrastructure Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'uptime of 99.99%' = alta disponibilidade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'uptime of 99.99%' = alta disponibilidade...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Infrastructure Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'Cenário: 'serviço precisa tolerar falha de um datacenter inteiro' = multi-AZ / multi-region.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'serviço precisa tolerar falha de um datacenter inteiro' = multi-A...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Aumentar recursos (CPU/RAM) da instância existente.

✓ **Por que está certa:** A alternativa correta é 'Aumentar recursos (CPU/RAM) da instância existente'. Escalabilidade vertical, também chamada de scale up, consiste em aumentar a capacidade de um único servidor ou instância adicionando mais recursos de hardware, como CPU, memória RAM, armazenamento ou largura de banda. O objetivo é tornar a máquina existente mais potente para lidar com maior carga. É um processo geralmente limitado pelo máximo de recursos que uma única máquina pode suportar e pode exigir reinicialização. A CompTIA define escalabilidade vertical como o aumento da capacidade de um recurso existente, em oposição à horizontal, que adiciona mais nós.

✗ **Por que as outras estão erradas:**

- *Adicionar mais instâncias:* Adicionar mais instâncias é escalabilidade horizontal (scale out), que aumenta a capacidade distribuindo a carga entre múltiplos servidores ou nós. É o oposto da vertical, que foca em fortalecer uma única instância. Portanto, não descreve scale up.
- *Distribuir carga entre regiões:* Distribuir carga entre regiões é uma estratégia de escalabilidade geográfica e de alta disponibilidade, geralmente associada a balanceamento de carga global e replicação entre regiões. Não é o conceito de escalabilidade vertical, que atua em um único servidor aumentando seus recursos.
- *Implementar auto scaling:* Auto scaling é um mecanismo que ajusta automaticamente a quantidade de instâncias (escalabilidade horizontal) com base em métricas como CPU ou tráfego. Embora possa incluir políticas de scale up e scale down, o termo 'auto scaling' normalmente se refere à elasticidade horizontal, não ao aumento de recursos de uma instância existente. Portanto, não define escalabilidade vertical.

2) A — Horizontalmente (scale out).

✓ **Por que está certa:** Escalar horizontalmente (scale out) significa aumentar a capacidade de um sistema adicionando mais máquinas ou instâncias ao pool de recursos, em vez de aumentar o poder de uma única máquina. No contexto de nuvem e arquitetura de sistemas distribuídos, essa abordagem é preferida para aplicações stateless e microsserviços, pois oferece maior resiliência, elasticidade e tolerância a falhas. A CompTIA Security+ SY0-701 aborda conceitos de escalabilidade como parte da disponibilidade e resiliência, e a definição exata de 'adicionar mais máquinas' corresponde a scale out (horizontal).

✗ **Por que as outras estão erradas:**

- *Verticalmente (scale up):* Escalar verticalmente (scale up) significa aumentar a capacidade de uma única máquina, adicionando mais CPU, memória, armazenamento ou poder de processamento. Isso não envolve adicionar mais máquinas, mas sim tornar uma máquina existente mais potente. A questão especifica 'adicionando MAIS máquinas (não máquinas maiores)', o que exclui explicitamente o scale up. Portanto, essa alternativa é o oposto do conceito descrito.
- *Pra baixo:* Escalar 'pra baixo' (scale down) refere-se à redução de capacidade, seja horizontal ou verticalmente, para economizar recursos. Não é um método de aumento de capacidade. A questão pergunta sobre aumentar capacidade, logo essa alternativa é semanticamente incorreta e não se aplica.
- *Manualmente:* Escalar manualmente não é um tipo de escalabilidade, mas sim um modo de operação. A escalabilidade pode ser manual ou automática, mas a questão pergunta sobre a direção do escalonamento (horizontal vs. vertical). 'Manualmente' não descreve a arquitetura de adição de máquinas, mas sim o processo de gestão, sendo uma resposta vaga e tecnicamente imprecisa.

3) A — Multi-tenancy.

✓ **Por que está certa:** Multi-tenancy é o modelo em que múltiplos clientes (tenants) compartilham a mesma infraestrutura física de um provedor de nuvem, mas são isolados logicamente por software, como hipervisores, contêineres, redes virtuais e políticas de IAM. Cada tenant enxerga apenas seus próprios recursos, como se estivesse em um ambiente dedicado. A CompTIA Security+ SY0-701 destaca que o multi-tenancy é um dos principais desafios de segurança na nuvem, exigindo isolamento rigoroso para evitar vazamento de dados entre clientes. A definição do enunciado corresponde exatamente a esse conceito.

✗ **Por que as outras estão erradas:**

- *Air gap:* Air gap é uma medida de segurança física que consiste em isolar completamente um sistema de redes externas, sem qualquer conexão física ou lógica. É o oposto de multi-tenancy, pois implica isolamento total e não compartilhamento de infraestrutura. Ambientes com air gap são usados em cenários de altíssima segurança, como sistemas militares ou industriais críticos, e não se aplicam à descrição de vários clientes dividindo a mesma infraestrutura.
- *Colocation:* Colocation é um modelo em que o cliente instala seus próprios servidores físicos em um datacenter de terceiros, alugando espaço, energia e conectividade. A infraestrutura física é compartilhada (prédio, energia), mas os servidores são dedicados a cada cliente. Não há isolamento por software da mesma forma que no multi-tenancy, pois cada cliente possui hardware próprio. Portanto, não corresponde à descrição de 'vários clientes dividindo a mesma infra física isolados por software'.
- *On-premises:* On-premises refere-se à infraestrutura de TI instalada e gerenciada dentro das instalações da própria organização, sem compartilhamento com outros clientes. É o oposto de multi-tenancy, pois não há provedor de nuvem nem compartilhamento de recursos físicos. A questão descreve um cenário de nuvem com múltiplos clientes, o que exclui completamente o modelo on-premises.

4) A — Auto scaling.

✓ **Por que está certa:** O Auto Scaling é um serviço que ajusta automaticamente a capacidade computacional (número de instâncias) com base em métricas de demanda, como uso de CPU, tráfego de rede ou filas. No CompTIA Security+ (domínio 3.4), ele é citado como solução de elasticidade e resiliência na nuvem, permitindo escalar horizontalmente para cima (aumentar instâncias) ou para baixo (reduzir) conforme a carga, garantindo disponibilidade e otimização de custos. É exatamente o que o enunciado descreve: 'ajustar automaticamente o número de instâncias conforme a demanda sobe/desce'.

✗ **Por que as outras estão erradas:**

- *Load balancing:* O Load Balancing (balanceamento de carga) distribui o tráfego de entrada entre múltiplas instâncias para evitar sobrecarga em um único servidor e melhorar a disponibilidade. Ele não aumenta ou diminui o número de instâncias automaticamente; apenas direciona requisições. Portanto, não é a resposta correta para ajuste automático de capacidade.
- *Snapshot:* Um Snapshot é uma cópia pontual de um volume de armazenamento (disco) ou de uma instância, usada para backup, recuperação de desastres ou clonagem. Ele não tem relação com ajuste dinâmico de instâncias conforme a demanda; é uma operação de backup, não de escalabilidade. Logo, está incorreto.
- *Failover:* O Failover é o processo de redirecionar automaticamente o tráfego para um sistema redundante (standby) quando o primário falha, garantindo continuidade. Ele não ajusta o número de instâncias conforme a demanda; apenas troca para um recurso de reserva em caso de falha. Portanto, não atende ao enunciado.

5) B — Implementar a solução correspondente: 99.9% de uptime = ~8h45 por ano permitindo downtime; 99.99% = 52 min....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Infrastructure Considerations): 99.9% de uptime = ~8h45 por ano permitindo downtime; 99.99% = 52 min.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: Elasticidade: escala pra cima E pra baixo conforme demanda....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Infrastructure Considerations): Elasticidade: escala pra cima E pra baixo conforme demanda.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Redundância N+1 = sobrevive 1 falha; 2N = sobrevive 2....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Infrastructure Considerations): Redundância N+1 = sobrevive 1 falha; 2N = sobrevive 2.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: 'ability to add/remove resources based on demand' = elasticidade....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Infrastructure Considerations): 'ability to add/remove resources based on demand' = elasticidade.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'uptime of 99.99%' = alta disponibilidade....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Infrastructure Considerations): 'uptime of 99.99%' = alta disponibilidade.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: Cenário: 'serviço precisa tolerar falha de um datacenter inteiro' = multi-A....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Infrastructure Considerations): Cenário: 'serviço precisa tolerar falha de um datacenter inteiro' = multi-AZ / multi-region..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

